DAWOOD UNIVERSITY OF ENGINEERING & TECHNOLOGY · DEPT OF COMPUTER SYSTEMS / INFOSEC

Demystifying the CIA Triad In Client-Side Encrypted Messaging

An institutional-grade client-side encryption messaging system built with W3C WebCrypto API, TOTP 2FA, and database-compromise defense.

PRESENTER

Muhammad Rehan (25f-cy-102)

@students.duet.edu.pk

CORE THEME

Applied Cryptography & CIA Triad Defense

Why DUETCLOCK > WhatsApp & Telegram

TECHNOLOGY STACK

Next.js · FastAPI · Supabase · WebCrypto

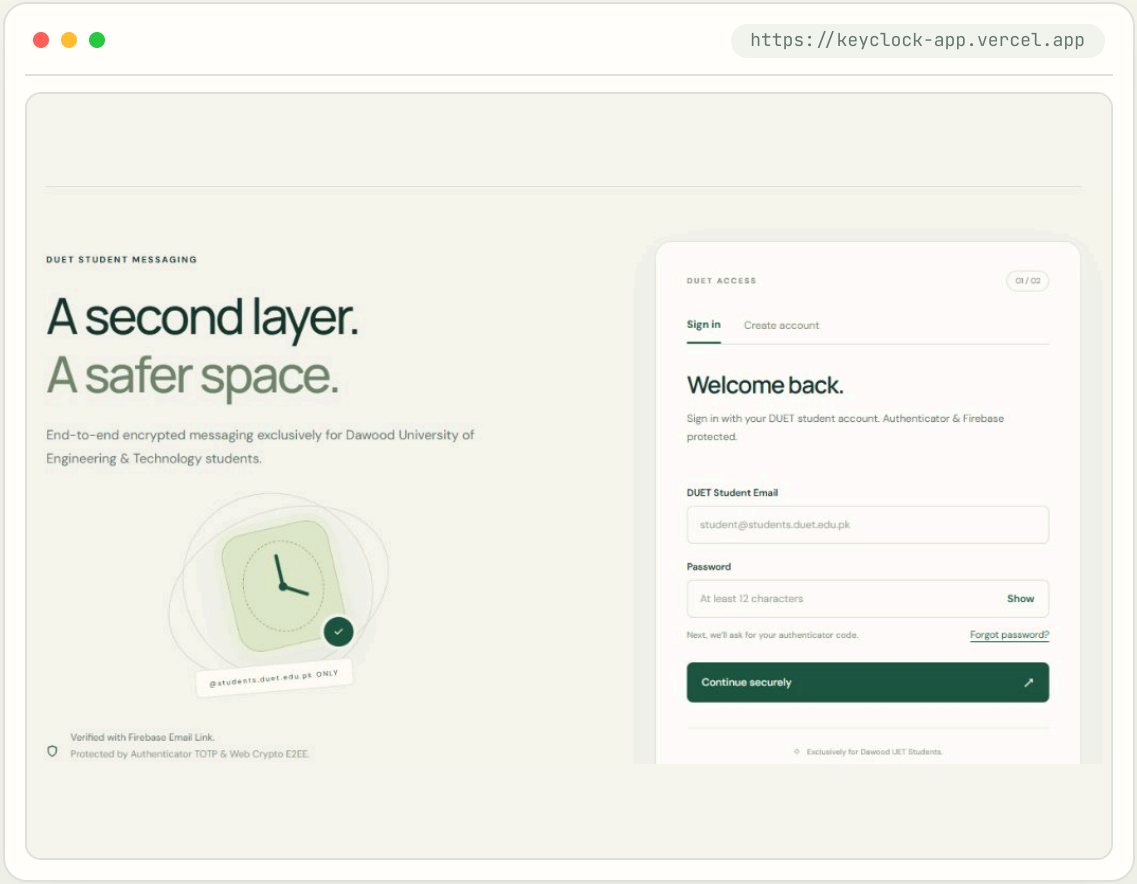
RSA-OAEP · AES-256-GCM · PBKDF2

THE ILLUSION OF PRIVACY

Why Commercial Messengers Fall Short

Commercial platforms trade user privacy for metadata mining, cellular carrier dependence, and centralized key custody.

- **Telegram's Dangerous Default:** All standard 1-on-1 and group chats are stored in decrypted form on Telegram servers. The server holds the decryption keys.
- **WhatsApp's Closed Metadata Mining:** While Signal protocol encrypts the message body, Meta's closed-source binary mines timestamps, social graphs, IP addresses, and contact books.
- **SIM-Swapping & SS7 Vulnerability:** Both platforms bind account identity to phone numbers, making them vulnerable to cellular carrier bribery and SS7 telecom interception.



DATABASE-BLIND ARCHITECTURE

Client-Side Cryptographic Vault

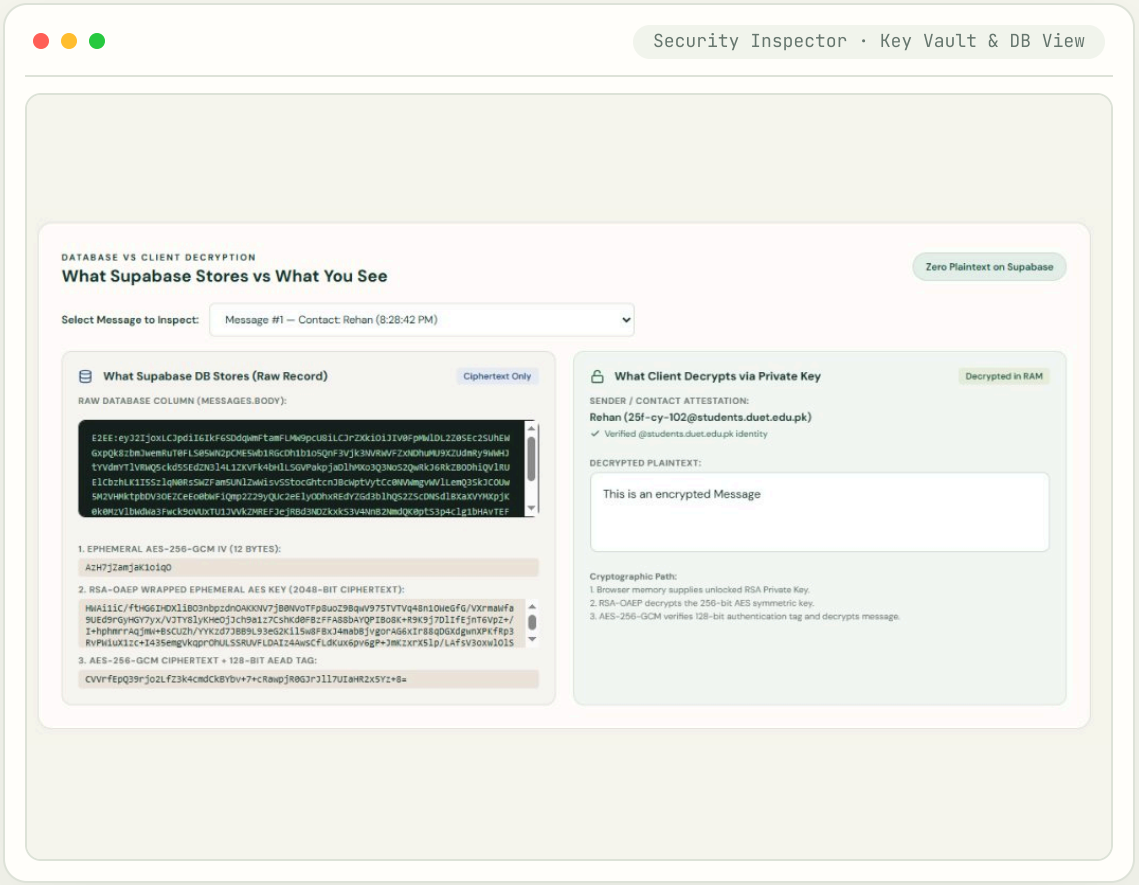
Plaintext messages and unencrypted private keys **never touch the network**.

Dual-Envelope Asymmetric Encryption

Each message generates an ephemeral `AES-256-GCM` key in browser RAM, wrapped using the recipient's `RSA-OAEP 2048-bit` public key.

Client-Wrapped Key Custody

Private keys are encrypted client-side with `PBKDF2` (600,000 SHA-256 rounds + 16-byte salt) before upload. Protects confidentiality against a database-only compromise.

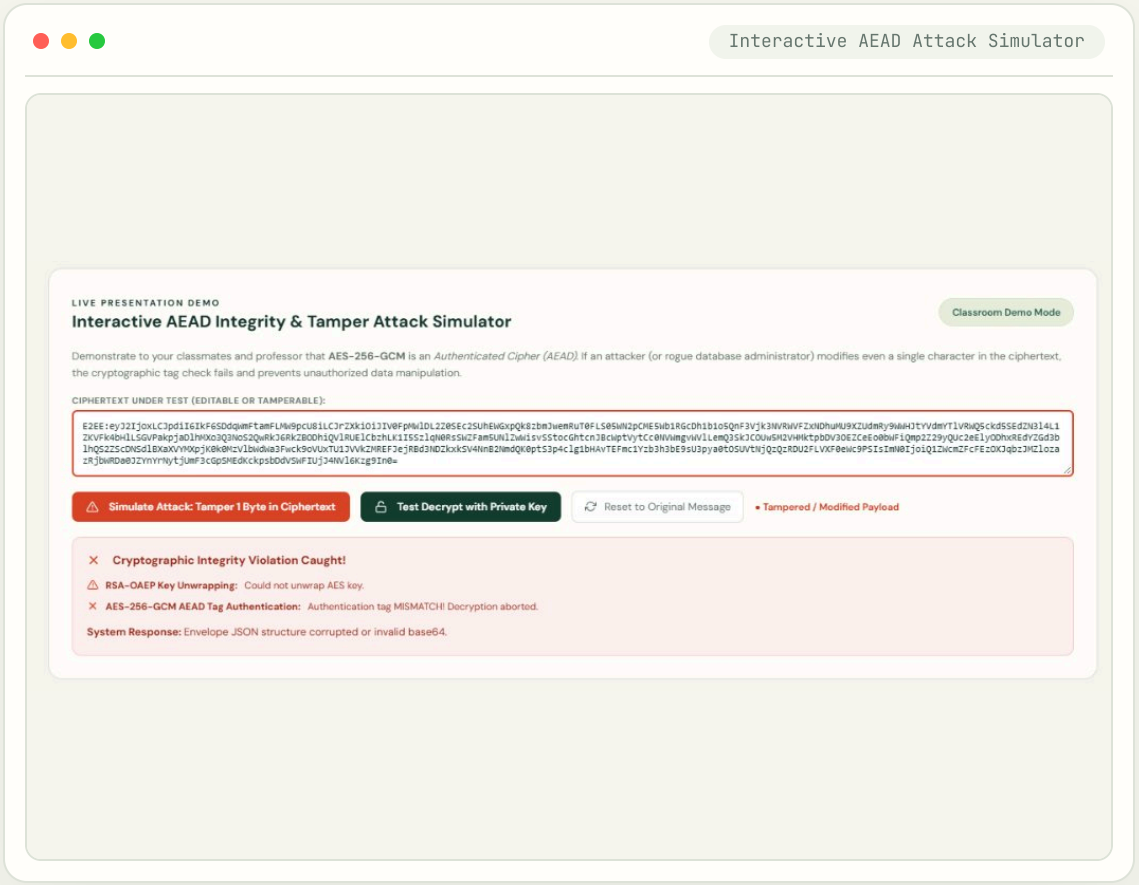


TAMPER-PROOF DATA ASSURANCE

Authenticated Encryption (AEAD)

Detecting and preventing unauthorized data manipulation both in transit and at rest.

- **128-bit Galois Authentication Tag:** `AES-256-GCM` calculates a cryptographic MAC. Corrupting even 1 single bit in the database triggers an instantaneous decryption rejection.
- **TOTP Replay Protection:** The backend increments a monotonic `last_counter` integer, preventing attackers from replaying captured 6-digit TOTP codes within the 30s window.
- **Constant-Time Verification:** Cryptographic comparisons use `secrets.compare_digest` to defeat timing side-channel attacks.



RESILIENCE & FAULT TOLERANCE

Service Continuity & Disaster Recovery

Protecting central infrastructure from denial of service while guaranteeing user disaster recovery.

Zero-CPU Crypto Offloading

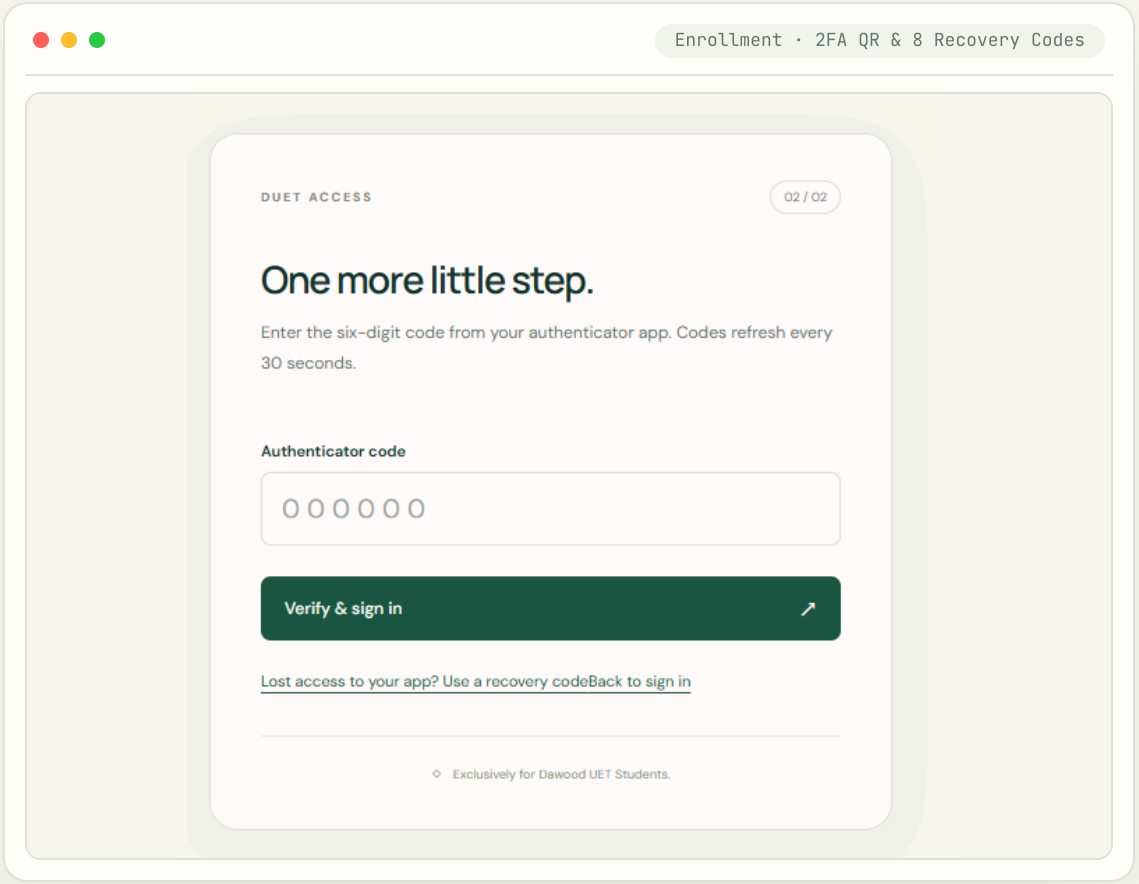
Cryptographic computation is offloaded 100% to client hardware using browser Web Crypto APIs, preventing Cryptographic Denial of Service (Crypto-DoS) on server CPUs.

Atomic Fixed-Window Throttles

Database-backed rate limiters enforce 5-attempt OTP lockouts alongside per-IP and per-account limits, tuned to mitigate brute-force and lockout abuse.

8 Disaster Recovery Codes

If a student loses or destroys their phone, 8 high-entropy one-time recovery codes (stored as SHA-256 digests) guarantee access recovery.

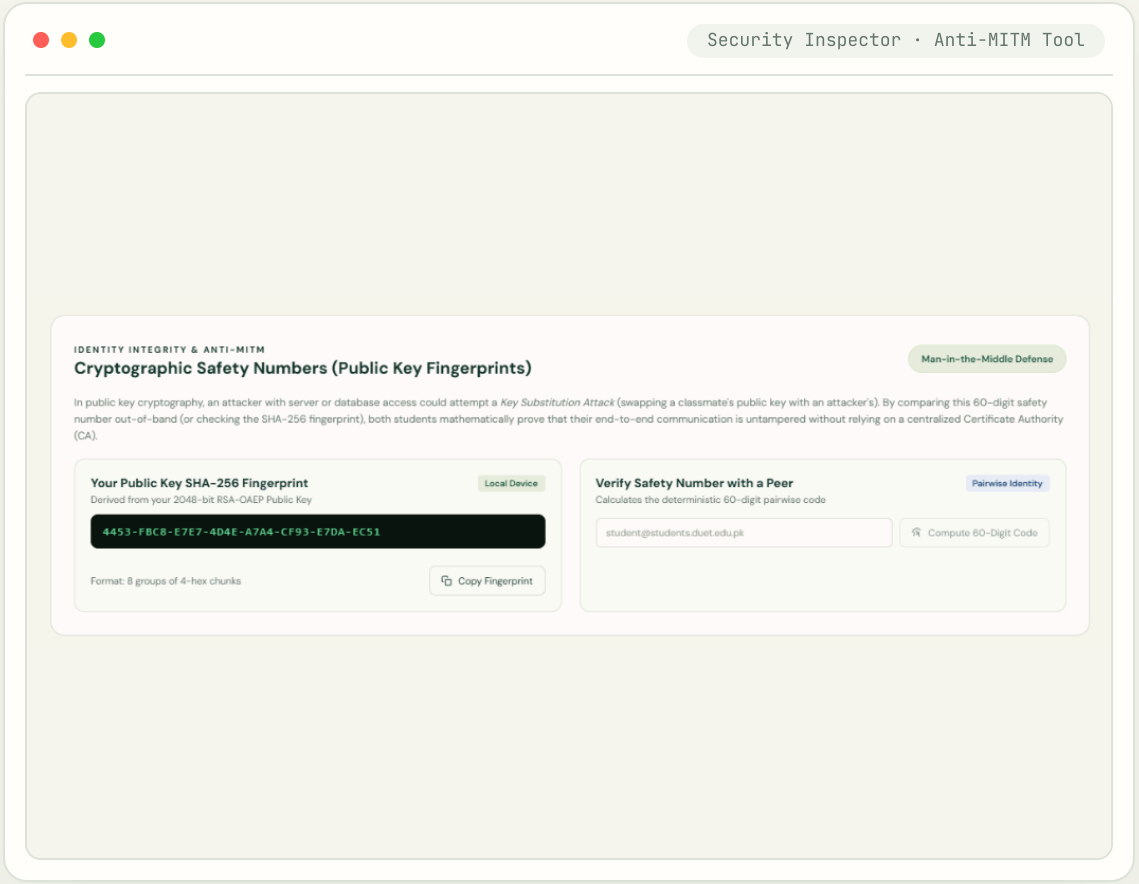


SOLVING THE PKI TRUST DILEMMA

60-Digit Cryptographic Safety Numbers

Mathematical defense against Key Substitution Attacks without relying on centralized Certificate Authorities.

1. **The Man-In-The-Middle Threat:** In standard PKI, a rogue database administrator could swap Alice's public key with Mallory's key to intercept messages.
2. **Deterministic Pairwise Hashing:** DUETCLOCK sorts both students' public keys lexicographically and iteratively hashes them to compute an identical 60-digit number on both devices.
3. **Out-of-Band Attestation:** Students verify this 60-digit sequence verbally or in class. If either key was altered by 1 bit, the digits diverge completely.



HEAD-TO-HEAD BENCHMARK

DUETCLOCK vs. WhatsApp vs. Telegram

Security Dimension	Telegram	WhatsApp	DUETCLOCK (Our Project)
Default E2EE	✕ **NOT by default** Cloud chats store server-side keys	✓ **Default E2EE** Signal Protocol	★ **Mandatory E2EE Envelope** Server strictly rejects plaintext (requires E2EE: prefix)
Cryptographic Standards	✕ **Proprietary "MTProto"** Custom non-standard MAC	✓ **Signal Protocol** Double Ratchet (Signal)	★ **W3C & NIST Standards** RSA-OAEP, AES-256-GCM, PBKDF2
Server Trust Model	✕ **Complete Server Trust** Telegram holds message keys	✕ **Closed Trust Model** Meta manages closed key distribution	★ **Database-Blind Storage** Protects against DB leak; not a malicious server
Metadata Harvesting	✕ **High Metadata Logging** Contacts, IPs, group rosters	✕ **Commercial Metadata Mining** Social graphs, timing, telemetry	★ **No Commercial Profiling** Server sees recipient & timestamp; no ad mining
Identity Attack Vector	✕ **SIM-Swap Vulnerable** Cellular SMS phone numbers	✕ **SIM-Swap Vulnerable** Carrier takeover susceptibility	★ **SIM-Swap Immune** @students.duet.edu.pk + RFC 6238 TOTP

Honest Security Model: Protects confidentiality against a **database-only leak** (an attacker or rogue DB admin who dumps Supabase sees only encrypted ciphertext). It does *not* claim protection against a malicious server, which sees routing metadata (who messages whom and when) and could observe login passwords to derive key-wrapping keys.

DEMONSTRATION ROADMAP

What We Are Presenting Live

A 3-minute interactive demonstration proving each cryptographic guarantee on a running system.

1. **Domain Fencing & TOTP Setup:** Live signup with `@students.duet.edu.pk`, Google Authenticator enrollment, and recovery code issuance.
2. **Dual-Envelope Text Delivery:** Sending an end-to-end encrypted message and inspecting the raw AES/RSA ciphertext blobs in Supabase PostgreSQL.
3. **Interactive AEAD Tamper Attack:** Corrupting 1 byte in the live inspector and witnessing the client-side cryptographic rejection.
4. **Pairwise Safety Numbers:** Verifying the 60-digit identity fingerprint between two students.

